

NexaPay

Plateforme de Paiement Numérique

Whitepaper Technique
Préparé pour
La Banque de Tunisie

Mai 2026

Glitch Inc — BackendGlitch Division
backendglitch.com | contact@backendglitch.com
nexapay.space | sandbox.nexapay.space

Contents

1	Présentation de NexaPay	3
1.1	URLs Publiques	3
1.2	Architecture	3
2	Sécurité	4
2.1	Mesures de Sécurité	4
2.2	Flux d'Authentification	4
3	Processus KYC (Know Your Customer)	5
3.1	Étapes du KYC	5
3.2	Données KYC Stockées	5
3.3	Conformité Réglementaire	5
4	Parcours Utilisateur	6
4.1	Inscription (6 étapes)	6
4.2	Fonctionnalités Utilisateur	6
4.3	Dépôt d'Argent en Agence	6
5	Programme Agent / Commerçant	7
5.1	Devenir Agent	7
5.2	Capacités de l'Agent	7
5.3	Intégration Technique	7
5.3.1	Exemple API	7
6	Blockchain et Traçabilité	8
6.1	Propriétés	8
7	Déploiement	9
7.1	Services Docker	9
8	Contact	10

1 Présentation de NexaPay

NexaPay est une plateforme fintech complète conçue pour le marché tunisien. Elle combine un portefeuille numérique, une passerelle de paiement pour commerçants, et un moteur blockchain propriétaire avec consensus BFT à 3 validateurs.

1.1 URLs Publiques

nexapay.space

Page d'accueil publique

sandbox.nexapay.space

Plateforme principale (dashboard, envois, carte)

auth.nexapay.space

Authentification (login, inscription)

backend.nexapay.space

API Backend

nexapay.space/docs

Documentation API & SDK

1.2 Architecture

- **Frontend** — Next.js 16 avec routage par sous-domaines
- **Backend** — Rust/Axum avec JWT, cookies httpOnly, AES-256-GCM
- **Blockchain** — Chaîne append-only, 3 validateurs BFT, signatures Ed25519
- **Base de données** — PostgreSQL 16 + SQLite + Sled
- **SDK** — @nexapay/node-sdk sur npm

2 Sécurité

NexaPay a été audité pour plus de 49 vulnérabilités. Toutes les vulnérabilités critiques et élevées sont résolues.

2.1 Mesures de Sécurité

Authentification et Sessions :

- JWT HS256 avec clés séparées utilisateur/admin
- Cookies httpOnly avec Domain, Secure, SameSite=Lax
- Sessions réversibles (révocation côté serveur)
- Rate limiting par IP sur toutes les routes sensibles

Données Sensibles :

- PIN haché avec Argon2id + salt aléatoire par utilisateur
- Cartes bancaires chiffrées AES-256-GCM (seul last4 visible)
- Clés privées Ed25519 chiffrées avec clé dérivée du PIN
- Comparaison OTP en temps constant (side-channel resistant)

Infrastructure :

- CORS restrictif (origins explicites, credentials activés)
- Webhooks signés HMAC-SHA256 avec 3 tentatives de retry
- Uploads validés (taille max 5 Mo, extensions whitelist, sanitization)
- Requêtes SQL paramétrées (SQLx), erreurs sanitizées
- Headers sécurité : X-Content-Type-Options, X-Frame-Options, Referrer-Policy

2.2 Flux d'Authentification

1. Utilisateur entre téléphone + PIN (6 chiffres)
2. Vérification PIN avec Argon2id
3. Envoi OTP 6 chiffres par SMS (Twilio)
4. Vérification OTP avec comparaison en temps constant
5. Cookie httpOnly + JWT stocké dans SecureStore (mobile) / localStorage (web)

3 Processus KYC (Know Your Customer)

Note : Le module KYC complet est disponible mais **désactivé pour la démo**. Les utilisateurs sont auto-vérifiés en mode sandbox. Le flux ci-dessous sera activé en production.

3.1 Étapes du KYC

1. Soumission des documents

- Photographie du **recto** et **verso** de la CIN
- Upload sécurisé avec validation (PNG, JPG, max 5 Mo)
- Stockage chiffré des documents

2. Extraction automatique (OCR)

- Nom, prénom, numéro CIN, date de naissance, date d'émission, lieu de naissance
- Croisement avec le formulaire d'inscription

3. Test de vivacité (Liveness Detection)

- Vérification via caméra (clignement, rotation tête, sourire)
- Score de correspondance faciale entre photo CIN et selfie
- Protection anti-photo et anti-vidéo

4. Vérification et approbation

- Score de vivacité > seuil requis ET données CIN correspondantes
- Compte marqué `kyc_status = verified`
- Accès complet à la plateforme

3.2 Données KYC Stockées

`kyc_cin_front_path` Chemin recto CIN

`kyc_cin_back_path` Chemin verso CIN

`kyc_face_match_score` Score correspondance faciale

`kyc_liveness_passed` Résultat test vivacité

`kyc_verified_at` Date/heure vérification

3.3 Conformité Réglementaire

Le processus est conforme avec la réglementation BCT, les directives LCB-FT, et la Loi n° 2004-63.

4 Parcours Utilisateur

4.1 Inscription (6 étapes)

1. **Téléphone** — Numéro tunisien (+216 XX XXX XXX)
2. **Informations personnelles** — Nom, prénom, email, date de naissance
3. **Identité** — Numéro CIN et date d'émission
4. **Contrat** — Signature électronique du contrat (Loi n° 2002-50)
5. **PIN** — Code 6 chiffres pour transactions
6. **Activation** — IBAN/RIB tunisien + carte Visa virtuelle + 150 TND offerts

4.2 Fonctionnalités Utilisateur

- **Portefeuille** — Solde TND, IBAN/RIB, carte Visa virtuelle
- **Envoi d'argent** — Transferts instantanés et gratuits entre utilisateurs
- **Virement bancaire** — Vers n'importe quel RIB tunisien
- **Rechargement** — Dépôt espèces en agence bancaire partenaire
- **Païement en ligne** — Checkout NexaPay chez les commerçants
- **Historique** — Transactions on-chain, vérifiables
- **Carte virtuelle** — Achats en ligne, gel/dégel

4.3 Dépôt d'Argent en Agence

1. Le client se rend dans une agence de **La Banque de Tunisie**
2. Il fournit son numéro de téléphone ou son adresse NexaPay
3. L'agent bancaire vérifie l'identité du client
4. Le dépôt en espèces est effectué au guichet
5. L'agent crédite le compte via l'interface administrateur
6. Le solde est mis à jour en temps réel

5 Programme Agent / Commerçant

5.1 Devenir Agent

1. **Candidature** — Formulaire avec nom commercial, type d'activité, matricule fiscal, adresse, volume estimé. Upload licence commerciale (PDF) et extrait RNE (PDF)
2. **Scoring** — Évaluation automatique du risque
3. **Approbation** — Automatique en sandbox, révision manuelle en production
4. **Activation** — Clé API unique, dashboard agent, limite de volume

5.2 Capacités de l'Agent

- **Liens de paiement** — Création de liens/QR codes pour accepter des paiements
- **API REST** — Intégration via API ou SDK Node.js
- **Remboursements** — Partiels ou totaux
- **Solde** — Disponible, volume brut, retraits
- **Retraits** — Transfert solde commercial → portefeuille personnel (on-chain)
- **Webhooks** — Notifications temps réel (succès/échec)
- **Statistiques** — Volume total, taux de succès, transactions du jour
- **Export** — CSV des transactions et clients

5.3 Intégration Technique

Trois modes d'intégration :

1. **No-Code** — Liens/QR codes depuis le dashboard
2. **SDK Node.js** — `npm install @nexapay/node-sdk`
3. **REST API** — Endpoints HTTP avec clé API

5.3.1 Exemple API

```
curl -X POST https://backend.nexapay.space/gateway/v1/intents \
  -H "Content-Type: application/json" \
  -H "X-API-Key: nxp_developer_CLE_API" \
  -d '{"amount":42000,"currency":"TND","description":"Cmd #42",
      "success_webhook_url":"https://maboutique.tn/hook/success"}'
```

6 Blockchain et Traçabilité

- **Consensus BFT** — 3 validateurs, quorum 3/3, signatures Ed25519
- **Registre immuable** — Toutes les transactions on-chain (append-only)
- **12 types de transactions** — Transfer, AccountCreate, EsignAccount, InvoiceAnchor, etc.
- **Ancrage** — Contrats signés et factures hashés et ancrés on-chain
- **Mempool** — 500 transactions max, expiration 5 minutes
- **Persistance** — Sled (blocs) + SQLite (snapshots)

6.1 Propriétés

- **Intégrité** — Chaque bloc référence le hash du bloc précédent
- **Non-répudiation** — Signatures Ed25519 sur transactions utilisateur
- **Auditabilité** — Toute transaction vérifiable indépendamment
- **Résilience** — 3 validateurs redondants

7 Déploiement

- **Serveur** — Azure VPS (Ubuntu 24.04)
- **Conteneurisation** — Docker Compose (6 conteneurs)
- **Proxy** — Nginx + Let's Encrypt (HTTPS/TLS 1.3)
- **Base de données** — PostgreSQL 16 (volume persistant)

7.1 Services Docker

postgres	:5432	Base de donn\’ees principale
validator-0	:8090	Valideur blockchain n0
validator-1	:8091	Valideur blockchain n1
validator-2	:8092	Valideur blockchain n2
validator-lb	:8088	Load balancer Nginx
nexapay-web	:3001	Frontend Next.js

8 Contact

Glitch Inc — BackendGlitch Division

Site web backendglitch.com
Email contact@backendglitch.com
GitHub github.com/Samer-Gassouma/NexaPay
SDK npm npmjs.com/package/@nexapay/node-sdk

Landing nexapay.space
Sandbox sandbox.nexapay.space
API Backend backend.nexapay.space
Documentation nexapay.space/docs

Merci de votre attention.

Disponible pour démonstration en direct et questions techniques.

Glitch Inc — BackendGlitch Division © 2026